

4.12 - Secure by design e OWASP para arquitetos

Segurança como propriedade do design, não remendo

Princípios de secure by design

Estrutura que resiste, não corrige depois

- **Superfície de ataque mínima reduz o que pode ser atacado**
 - Menos endpoints, menos portas, menos exposição
- **Menor privilégio dá só o acesso estritamente necessário**
 - Comprometer um componente não compromete tudo
- **Defesa em profundidade empilha camadas independentes**
 - Falha de uma camada não derruba a proteção inteira
- **Fail secure: ao falhar, negar o acesso por padrão**

Corrigir depois ou projetar seguro

Segurança como remendo

- Bug encontrado depois, em produção
- Patch corrige o sintoma pontual
- Mesma falha reaparece em outro lugar
- Custo cresce a cada incidente

Segurança por design

- Risco endereçado na fase de desenho
- Estrutura resiste à classe inteira de falha
- Decisão arquitetural, não correção isolada
- Custo concentrado no início, menor no total

O que o pentest encontrou

- **Pentest contratado pelo cliente enterprise**
 - Dois problemas críticos de design, não de código

LUNALOG

Um pentest contratado pelo cliente enterprise encontrou dois problemas críticos na LunaLog. O primeiro era broken access control: usuários conseguiam acessar recursos de outros tenants apenas manipulando IDs na URL. O segundo era server-side request forgery, em que um endpoint de integração permitia fazer o servidor da LunaLog disparar requisições para endpoints internos. Roberto queria tratar os dois como bugs, corrigir com um patch rápido. Ana mostrou que ambos eram falhas de design arquitetural, e que um patch só esconderia o sintoma. Os dois exigiram redesign estrutural, não correção pontual.

OWASP Top 10 na lente do arquiteto

- **Broken access control é falha de design, não de código**
 - Autorização precisa ser estrutural, não pontual
- **SSRF nasce de confiar cegamente em entrada de URL**
 - Segregar rede e validar destino mitiga na origem
- **Falha criptográfica vem de decisão arquitetural ruim**
 - Onde cifrar e como guardar a chave é design
- **OWASP vira mapa de decisões, não lista de bugs**

Nem toda vulnerabilidade tem patch

- Broken access control e SSRF são exemplos clássicos
- São consequência da estrutura, não de uma linha errada

Quando a vulnerabilidade nasce do design, o patch só esconde o sintoma. A correção real é redesenhar a fronteira de confiança.

- Por isso o arquiteto precisa entrar antes do código



O sistema agora é seguro por design. Mas em arquiteturas de microsserviços existe um pressuposto perigoso e quase invisível: tratar a rede interna como zona de confiança. Se estar dentro da rede já dá acesso, basta um pé lá dentro para comprometer tudo. Como derrubar essa confiança implícita sem reescrever a aplicação?

Zero trust, service mesh e secrets management